

# **CAPSTONE PROJECT & INCIDENT RESPONSE**

## **Task 5 — Professional Security Assessment Report**

Metasploitable 2 Controlled Laboratory Assessment

Kali Linux: 192.168.47.132

Metasploitable 2: 192.168.47.133

Network: 192.168.47.0/24 isolated laboratory network

Tools: Nmap, cURL, Metasploit Framework

## 1. Executive Summary

This report documents a controlled cybersecurity capstone assessment against an intentionally vulnerable Metasploitable 2 virtual machine. The work covered reconnaissance, service enumeration, vulnerability identification, selected manual validation, evidence collection, and an incident-response simulation.

The target exposed a broad attack surface including FTP, SSH, Telnet, SMTP, DNS, HTTP, SMB, RMI, NFS, MySQL, PostgreSQL, VNC, IRC and Apache Tomcat. Key findings included the vsFTPD 2.3.4 backdoor condition, insecure Java RMI remote class loading, an outdated Apache/PHP stack, and WebDAV write/delete capability.

A harmless WebDAV test file was created through HTTP PUT and returned 201 Created, verified by retrieval, deleted with HTTP 204 No Content, detected in Apache logs, and finally confirmed absent with HTTP 404 Not Found.

## 2. Scope and Objectives

Testing was restricted to the intentionally vulnerable Metasploitable 2 VM in the isolated laboratory network.

- Verify connectivity and identify the target.
- Enumerate exposed services and versions.
- Identify known vulnerabilities and insecure configurations.
- Manually validate selected findings.
- Demonstrate controlled WebDAV write/delete behavior.
- Simulate detection, eradication and verification.
- Document findings, risk and mitigation strategies.

## 3. Test Environment

| Component          | Details                              |
|--------------------|--------------------------------------|
| Assessment machine | Kali Linux — 192.168.47.132          |
| Target             | Metasploitable 2 — 192.168.47.133    |
| Network            | 192.168.47.0/24 isolated lab network |
| Virtualization     | VMware                               |
| Primary tools      | Nmap, cURL, Metasploit Framework     |
| Target purpose     | Intentionally vulnerable training VM |

### 3.1 Network / Attack Diagram

Kali Linux (192.168.47.132) → isolated 192.168.47.0/24 → Metasploitable 2 (192.168.47.133)

Assessment: Nmap / cURL / Metasploit

Target: legacy FTP/HTTP/WebDAV/RMI and other exposed services.

## 4. Methodology

### Reconnaissance

Verified reachability and target network context.

### Service Enumeration

Performed Nmap service/version detection.

## Vulnerability Identification

Used Nmap vulnerability scripts and focused NSE checks.

## Manual Validation

Used cURL for HTTP/WebDAV and Metasploit for the vsFTPD validation attempt.

## Incident Response

Created a controlled WebDAV event, detected it in Apache logs, removed the artifact and verified removal.

## 5. Key Findings

| Finding                       | Port          | Evidence / Validation                                                                         | Severity      | Recommended Action                                                |
|-------------------------------|---------------|-----------------------------------------------------------------------------------------------|---------------|-------------------------------------------------------------------|
| vsFTPD 2.3.4 backdoor         | 21/tcp        | Nmap reported VULNERABLE/Exploitable and a root-level result; Metasploit produced no session. | Critical      | Upgrade/remove vulnerable FTP; restrict access.                   |
| Java RMI remote class loading | 1099/tcp      | rmi-vuln-classloader reported VULNERABLE and remote class loading capable of leading to RCE.  | Critical/High | Disable/restrict RMI; disable remote class loading; patch.        |
| WebDAV write/delete           | 80/tcp        | PROPFIND confirmed DAV; PUT 201; retrieval succeeded; DELETE 204.                             | High          | Disable PUT/DELETE unless required; restrict/authenticate WebDAV. |
| HTTP configuration/disclosure | 80/tcp        | Apache 2.2.8/PHP 5.2.4 disclosure; TRACE, phpinfo, phpMyAdmin and test resources identified.  | High/Medium   | Upgrade; disable TRACE; remove/restrict exposed resources.        |
| Legacy SSL/TLS weaknesses     | Scan-reported | DROWN/SSLv2 and other weak cryptographic configurations identified.                           | High          | Disable legacy protocols; modernize TLS.                          |

## 6. Service Enumeration

Nmap identified FTP, SSH, Telnet, SMTP, DNS, HTTP, RPCBind, SMB, R-services, Java RMI, NFS, MySQL, PostgreSQL, VNC, IRC and Apache Tomcat. The breadth of exposed services indicates a large attack surface.

```

kali@kali:~/task5-capstone$ sudo nmap -p 21,22,23,25,53,80,111,139,445,512,513,514,1099,1524,2049,2121,3306,5432,5900,6000,6667,8009,8180 -sV 192.168.47.133 -oN task5_exposed_services.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-17 23:07 +0530
Nmap scan report for 192.168.47.133
Host is up (0.0013s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  cproxy-ftp?
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:12:CA:07 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 177.17 seconds

```

Figure 1. Nmap service/version enumeration.

## 7. High-Risk Vulnerability Validation

### 7.1 vsFTPD 2.3.4 Backdoor

TCP/21 was identified as vsFTPD 2.3.4. The vulnerability evidence reports CVE-2011-2523 and an exploitable backdoor condition. A Metasploit validation attempt was performed, but no interactive session was created; this report therefore does not claim successful session establishment.

```

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.47.133
RHOSTS => 192.168.47.133
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RPORT 21
RPORT => 21
msf exploit(unix/ftp/vsftpd_234_backdoor) > set payload cmd/unix/interact
[-] The value specified for payload is not valid.
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):



| Name   | Current Setting | Required | Description                                                                                            |
|--------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| RHOSTS | 192.168.47.133  | yes      | The target host(s). see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                  |



Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):



| Name           | Current Setting | Required | Description                                                                                                                                                                                                              |
|----------------|-----------------|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| EXTENSIONS     |                 | no       | Comma-separated list of extensions to load                                                                                                                                                                               |
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, GET, TFTP, INFTP, WGET)                                                                                                                                                   |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                                                                             |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux >=3.17 (for Python variant also Python >=3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell) |
| FETCH_SRVHOST  |                 | no       | Local IP to use for serving payload                                                                                                                                                                                      |
| FETCH_SRVPORT  | 8080            | yes      | Local port to use for serving payload                                                                                                                                                                                    |
| FETCH_URIIPATH |                 | no       | Local URI to use for serving payload                                                                                                                                                                                     |
| LHOST          | 192.168.47.132  | yes      | The listen address (an interface may be specified)                                                                                                                                                                       |
| LPORT          | 4444            | yes      | The listen port                                                                                                                                                                                                          |



When FETCH_COMMAND is one of CURL,GET,WGET:



| Name       | Current Setting | Required | Description                                                                            |
|------------|-----------------|----------|----------------------------------------------------------------------------------------|
| FETCH_PIPE | false           | yes      | Host both the binary payload and the command so it can be piped directly to the shell. |


```

Figure 2. Metasploit validation attempt.

### 7.2 Java RMI Remote Class Loading

TCP/1099 was identified as GNU Classpath grmiregistry. The rmi-vuln-classloader script reported VULNERABLE because the default configuration allowed remote class loading that can lead to remote code execution.

```

(kali@kali)-[~/task5-capstone]
$ nc -nv 192.168.47.133 1099
(UNKNOWN) [192.168.47.133] 1099 (rmiregistry) open
^C

(kali@kali)-[~/task5-capstone]
$ sudo nmap -p 1099 -sV --script rmi-vuln-classloader 192.168.47.133 -oN task5_rmi_validation.txt
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-17 23:03 +0530
Nmap scan report for 192.168.47.133
Host is up (0.00056s latency).

PORT      STATE SERVICE VERSION
1099/tcp  open  java-rmi GNU Classpath grmiregistry
| rmi-vuln-classloader:
|   VULNERABLE:
|     RMI registry default configuration remote code execution vulnerability
|     State: VULNERABLE
|       Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote code execution.
|   References:
|     https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/multi/misc/java_rmi_server.rb
|_  MAC Address: 00:0C:29:12:CA:07 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.83 seconds

```

Figure 3. RMI vulnerability validation.

## 8. WebDAV Manual Validation

PROPFIND confirmed a WebDAV collection at /dav/. A harmless file was uploaded with HTTP PUT, returning 201 Created; it was retrieved successfully and deleted with HTTP 204 No Content.

```

(kali@kali)-[~/]
$ curl -i -X PROPFIND -H "Depth: 1" http://192.168.47.133/dav/ | tee task5_webdav_propfind.txt
% Total    % Received % Xferd  Average Speed   Time    Time     Time    Current
           Dload  Upload  Total   Spent    Left     Speed

100    841  100    841    0     0  84344      0    0     0      0      0     0
HTTP/1.1 207 Multi-Status
Date: Mon, 17 Aug 2026 17:41:15 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
Content-Length: 841
Content-Type: text/xml; charset="utf-8"

<?xml version="1.0" encoding="utf-8"?>
<D:multistatus xmlns:D="DAV:">
  <D:response xmlns:lp1="DAV:" xmlns:lp2="http://apache.org/dav/props/">
    <D:href>/dav/</D:href>
    <D:propstat>
      <D:prop>
        <lp1:resourcetype><D:collection/></lp1:resourcetype>
        <lp1:creationdate>2012-05-20T19:30:29Z</lp1:creationdate>
        <lp1:getlastmodified>Sun, 20 May 2012 19:30:29 GMT</lp1:getlastmodified>
        <lp1:getetag>"10817-1000-4c07cd16e7f40"</lp1:getetag>
        <D:supportedlock>
          <D:lockentry>
            <D:lockscope><D:exclusive/></D:lockscope>
            <D:locktype><D:write/></D:locktype>
          </D:lockentry>
          <D:lockentry>
            <D:lockscope><D:shared/></D:lockscope>
            <D:locktype><D:write/></D:locktype>
          </D:lockentry>
        </D:supportedlock>
        <D:lockdiscovery/>
        <D:getcontenttype>httpd/unix-directory</D:getcontenttype>
      </D:prop>
      <D:status>HTTP/1.1 200 OK</D:status>
    </D:propstat>
  </D:response>
</D:multistatus>

```

Figure 4. WebDAV PROPFIND response.

```

(kali@kali)-[~]
$ cd ~/task5-capstone

printf 'Task 5 WebDAV write test\n' > dav_test.txt

curl -i -T dav_test.txt http://192.168.47.133/dav/ dav_test.txt
HTTP/1.1 201 Created
Date: Mon, 17 Aug 2026 17:42:46 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
Location: http://192.168.47.133/dav/dav_test.txt
Content-Length: 276
Content-Type: text/html; charset=ISO-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>201 Created</title>
</head><body>
<h1>Created</h1>
<p>Resource /dav/dav_test.txt has been created.</p>
<hr />
<address>Apache/2.2.8 (Ubuntu) DAV/2 Server at 192.168.47.133 Port 80</address>
</body></html>
curl: (6) Could not resolve host: dav_test.txt

(kali@kali)-[~/task5-capstone]
$ curl -i -X PUT --data-binary @dav_test.txt http://192.168.47.133/dav/dav_test.txt | tee task5_webdav_put.txt
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           % Dload  Upload Total   Spent    Left     Speed

100    25    0    0 100    25    0 3082
HTTP/1.1 204 No Content
Date: Mon, 17 Aug 2026 17:43:18 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
Content-Length: 0
Content-Type: text/plain

```

Figure 5. WebDAV PUT returning HTTP 201 Created.

```

(kali@kali)-[~/task5-capstone]
$ curl -i http://192.168.47.133/dav/dav_test.txt | tee task5_webdav_verify.txt
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           % Dload  Upload Total   Spent    Left     Speed

100    25 100    25    0    0 2644    0
HTTP/1.1 200 OK
Date: Mon, 17 Aug 2026 17:44:00 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
Last-Modified: Mon, 17 Aug 2026 17:43:18 GMT
ETag: "1081e-19-65941b499f980"
Accept-Ranges: bytes
Content-Length: 25
Content-Type: text/plain

Task 5 WebDAV write test

(kali@kali)-[~/task5-capstone]
$ curl -i -X DELETE http://192.168.47.133/dav/dav_test.txt | tee task5_webdav_delete.txt
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           % Dload  Upload Total   Spent    Left     Speed

0    0    0    0 0    0    0 0
HTTP/1.1 204 No Content
Date: Mon, 17 Aug 2026 17:44:17 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
Content-Length: 0
Content-Type: text/plain

```

Figure 6. Retrieval and DELETE returning HTTP 204.

## 9. Incident Response Simulation

A harmless file named `incident_test.txt` was used as the simulated unauthorized artifact. The sequence was: HTTP PUT → detection in Apache access.log → HTTP DELETE → GET verification.

| Phase     | Action                           | Evidence                             | Result              |
|-----------|----------------------------------|--------------------------------------|---------------------|
| Simulate  | PUT<br>/dav/incident_test.txt    | Apache response                      | 201 Created         |
| Detect    | Search access.log                | Source 192.168.47.132 +<br>PUT entry | Activity identified |
| Eradicate | DELETE<br>/dav/incident_test.txt | Apache response                      | 204 No Content      |
| Verify    | GET after deletion               | Apache response                      | 404 Not Found       |

The Apache log recorded the source 192.168.47.132 and the PUT request for `/dav/incident_test.txt`. After eradication, DELETE returned 204 and a subsequent GET returned 404, confirming removal.

```
msfadmin@metasploitable:~$ sudo grep "incident_test.txt" /var/log/apache2/access
.log | tee /tmp/webdav_incident_log.txt
192.168.47.132 - - [17/Aug/2026:14:00:35 -0400] "PUT /dav/incident_test.txt HTTP
/1.1" 201 281 "-" "curl/8.21.0"
192.168.47.132 - - [17/Aug/2026:14:03:04 -0400] "PUT /dav/incident_test.txt HTTP
/1.1" 204 - "-" "curl/8.21.0"
msfadmin@metasploitable:~$ cat /tmp/webdav_incident_log.txt
192.168.47.132 - - [17/Aug/2026:14:00:35 -0400] "PUT /dav/incident_test.txt HTTP
/1.1" 201 281 "-" "curl/8.21.0"
192.168.47.132 - - [17/Aug/2026:14:03:04 -0400] "PUT /dav/incident_test.txt HTTP
/1.1" 204 - "-" "curl/8.21.0"
msfadmin@metasploitable:~$
```

Figure 7. Apache access-log evidence showing WebDAV PUT activity.



```
(kali㉿kali)-[~/task5-capstone]
$ curl -i -X DELETE http://192.168.47.133/dav/incident_test.txt \
| tee evidence/incident-response/webdav_eradication.txt
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           0         0     0           0          0      0      0      0
HTTP/1.1 204 No Content
Date: Mon, 17 Aug 2026 18:05:50 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
Content-Length: 0
Content-Type: text/plain

(kali㉿kali)-[~/task5-capstone]
$ curl -i http://192.168.47.133/dav/incident_test.txt
HTTP/1.1 404 Not Found
Date: Mon, 17 Aug 2026 18:05:58 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
Content-Length: 304
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL /dav/incident_test.txt was not found on this server.</p>
<hr>
<address>Apache/2.2.8 (Ubuntu) DAV/2 Server at 192.168.47.133 Port 80</address>
</body></html>
```

Figure 8. Eradication and post-removal 404 verification.

10. Risk Analysis and Mitigation

| Priority      | Issue                    | Recommended Mitigation                                                          |
|---------------|--------------------------|---------------------------------------------------------------------------------|
| Critical      | vsFTPD 2.3.4             | Upgrade/remove; restrict FTP; prefer secure alternatives.                       |
| Critical/High | RMI remote class loading | Disable if unnecessary; restrict TCP/1099; disable remote class loading; patch. |
| High          | WebDAV write/delete      | Disable PUT/DELETE unless required; authenticate/restrict WebDAV; monitor logs. |
| High          | Outdated Apache/PHP      | Upgrade; remove phpinfo/test resources; restrict phpMyAdmin; disable TRACE.     |
| High          | Legacy TLS/crypto        | Disable SSLv2/SSLv3; use modern TLS and strong parameters.                      |
| General       | Large attack surface     | Remove unnecessary services; apply firewall rules and network segmentation.     |

11. Incident Response Lessons Learned

- Searchable web-server logs are essential for identifying suspicious write activity.
- A 201 response can indicate successful creation of an unauthorized resource.
- Containment should remove unauthorized artifacts and restrict the mechanism that enabled creation.



- Post-remediation verification is required; 404 confirmed the artifact was no longer available.
- Write-capable WebDAV functionality should be tightly controlled.

## 12. Limitations

- Testing was limited to the intentionally vulnerable Metasploitable 2 laboratory VM.
- Not every scanner finding was manually exploited; scanner states such as LIKELY VULNERABLE require further validation.
- The vsFTPD validation did not create an interactive session.
- The WebDAV incident used a harmless test file.

## 13. Conclusion

The capstone demonstrated an end-to-end security workflow from reconnaissance through incident response. The environment contained numerous legacy services and serious weaknesses. The WebDAV scenario provided a complete attack-and-response demonstration: creation, detection, eradication and verification. Recommended remediation focuses on minimizing the attack surface, upgrading legacy software, restricting administrative and write-capable interfaces, disabling unnecessary protocols and monitoring continuously.

## Appendix A — Evidence Inventory

- task5\_exposed\_services.txt
- task5\_full\_scan.txt / task5\_vulnerability\_scan.txt
- task5\_rmi\_validation.txt
- task5\_webdav\_listing.xml
- task5\_webdav\_put.txt
- task5\_webdav\_verify.txt
- task5\_webdav\_delete.txt
- task5\_webdav\_options.txt / task5\_webdav\_propfind.txt
- evidence/incident-response/webdav\_attack.txt
- webdav\_incident\_log.txt
- evidence/incident-response/webdav\_eradication.txt